

# Security design principles

A Well-Architected workload must be built with a zero-trust approach. A secure workload is **resilient to attacks** and incorporates the interrelated security **principles of confidentiality, integrity, and availability** (also known as the *CIA triad*) in addition to meeting business goals. Any security incident has the potential to become a major breach that damages the brand and reputation of the workload or organization. To measure the security efficacy of your overall strategy for a workload, start with these questions:

- Do your defensive investments provide meaningful cost and friction to prevent attackers from compromising your workload?
- Will your security measures be effective in restricting the blast radius of an incident?
- Do you understand how controlling the workload could be valuable for an attacker? Do you understand the impact to your business if the workload and its data are stolen, unavailable, or tampered with?
- Can the workload and operations quickly detect, respond to, and recover from disruptions?

As you design your system, use the Microsoft Zero Trust model as the compass to mitigate security risks:

- **Verify explicitly** so that **only trusted identities** perform **intended and allowed actions** that originate from **expected locations**. This safeguard makes it harder for attackers to impersonate legitimate users and accounts.
- **Use least-privilege access** for the **right identities**, with the **right set of permissions**, for the **right duration**, and to the **right assets**. Limiting permissions helps keep attackers from abusing permissions that legitimate users don't even need.
- **Assume breach** of security controls and design compensating controls that **limit risk and damage** if a primary layer of defense fails. Doing so helps you to defend your workload better by thinking like an attacker who's interested in success (regardless of how they get it).

Security isn't a one-time effort. You must implement this guidance on a recurring basis. Continuously improve your defenses and security knowledge to help keep your workload safe

from attackers who are constantly gaining access to innovative attack vectors as they're developed and added to automated attack kits.

The design principles are intended to establish an ongoing security mindset to help you continuously improve the security posture of your workload as the attempts of attackers continuously evolve. These principles should guide the security of your architecture, design choices, and operational processes. Start with the recommended approaches and **justify the benefits for a set of security requirements**. After you set your strategy, drive actions by using the [Security checklist](#) as your next step.

If these principles aren't applied properly, a negative impact on business operations and revenue can be expected. Some consequences might be obvious, like penalties for regulatory workloads. Others might not be so obvious and could lead to ongoing security problems before they're detected.

In many mission-critical workloads, security is the primary concern, alongside reliability, given that some attack vectors, like data exfiltration, don't affect reliability. Security and reliability can pull a workload in opposite directions because security-focused design can introduce points of failure and increase operational complexity. The effect of security on reliability is often indirect, introduced by way of operational constraints. Carefully consider tradeoffs between security and reliability.

By following these principles, you can improve security effectiveness, harden workload assets, and build trust with your users.

## Plan your security readiness

 Expand table



**Strive to adopt and implement security practices in architectural design decisions and operations with minimal friction.**

As a workload owner, you have a shared responsibility with the organization to protect assets. Create a **security readiness plan** that's aligned with business priorities. It will lead to well-defined processes, adequate investments, and appropriate accountabilities. The plan should provide the workload requirements to the organization, which also shares responsibility for protecting assets. Security plans should factor into your strategy for reliability, health modeling, and self-preservation.

In addition to organizational assets, the workload itself needs to be protected from intrusion and exfiltration attacks. All facets of Zero Trust and the CIA triad should be factored into the plan.

Functional and non-functional requirements, budget constraints, and other considerations shouldn't restrict security investments or dilute assurances. At the same time, you need to engineer and plan security investments with those constraints and restrictions in mind.

[Expand table](#)

| Approach                                                                                                                                                                                                                                                                                                                                                      | Benefit                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Use segmentation as a strategy to plan security boundaries</b> in the workload environment, processes, and team structure to <b>isolate access and function</b>.</p> <p>Your segmentation strategy should be driven by business requirements. You can base it on criticality of components, division of labor, privacy concerns, and other factors.</p> | <p>You'll be able to <b>minimize operational friction</b> by defining roles and establishing <b>clear lines of responsibility</b>. This exercise also helps you <b>identify the level of access</b> for each role, especially for critical-impact accounts.</p> <p>Isolation enables you to <b>limit exposure of sensitive flows</b> to only roles and assets that need access. Excessive exposure could inadvertently lead to information flow disclosure.</p> <p>To summarize, you'll be able to <b>right-size security efforts</b> based on the needs of each segment.</p>                                      |
| <p>Continuously <b>build skills</b> through <b>role-based security training</b> that meets the requirements of the organization and the use cases of the workload.</p>                                                                                                                                                                                        | <p>A highly skilled team can design, implement, and monitor <b>security controls that remain effective</b> against attackers, who constantly look for new ways to exploit the system.</p> <p>Organization-wide training typically focuses on developing a broader skill set for securing the common elements. However, with role-based training, you focus on <b>developing deep expertise</b> in the platform offerings and security features that address workload concerns.</p> <p>You need to implement both approaches to defend against adversaries through <b>good design and effective operations</b>.</p> |
| <p><b>Make sure there's an incident response plan</b> for your workload.</p> <p>Use industry frameworks that define the standard operating procedure for preparedness, detection, containment, mitigation, and post-incident activity.</p>                                                                                                                    | <p>At the time of crisis, confusion must be avoided.</p> <p>If you have a well-documented plan, responsible roles can <b>focus on execution</b> without wasting time on uncertain actions. Also, a comprehensive plan can help you ensure that <b>all remediation requirements are fulfilled</b>.</p>                                                                                                                                                                                                                                                                                                              |

| Approach                                                                                                                                                                                                                                                             | Benefit                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Strengthen your security posture by understanding the security compliance requirements</b> that are imposed by influences outside the workload team, like organizational policies, regulatory compliance, and industry standards.</p>                          | <p>Clarity about compliance requirements will help you <b>design for the right security assurances</b> and <b>prevent non-compliance</b> issues, which could lead to penalties.</p> <p>Industry standards can provide a baseline and influence your choice of tools, policies, security safeguards, guidelines, risk-management approaches, and training.</p> <p>If you know that the workload adheres to compliance, you'll be able to <b>instill confidence</b> in your user base.</p> |
| <p><b>Define and enforce team-level security standards</b> across the lifecycle and operations of the workload.</p> <p><b>Strive for consistent practices</b> in operations like coding, gated approvals, release management, and data protection and retention.</p> | <p>Defining good security practices can <b>minimize negligence</b> and the surface area for potential errors. The team will <b>optimize efforts and the outcome will be predictable</b> because approaches are made more consistent.</p> <p>Observing security standards over time will enable you to <b>identify opportunities for improvement, possibly including automation</b>, which will streamline efforts further and increase consistency.</p>                                  |
| <p>Align your incident response with the <b>Security Operation Center (SOC) centralized function</b> in your organization.</p>                                                                                                                                       | <p>Centralizing incident response functions enables you to take advantage of specialized IT professionals who can detect incidents in real time to address potential threats as quickly as possible.</p>                                                                                                                                                                                                                                                                                 |

## Design to protect confidentiality

 Expand table



**Prevent exposure to privacy, regulatory, application, and proprietary information through access restrictions and obfuscation techniques.**

Workload data can be classified by user, usage, configuration, compliance, intellectual property, and more. That data can't be shared or accessed beyond the established trust boundaries. Efforts to protect confidentiality should focus on access controls, opacity, and keeping an audit trail of activities that pertain to data and the system.

 Expand table

| Approach                                                                                                                                                                                              | Benefit                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Implement <b>strong access controls</b> that grant access only on a need-to-know basis.                                                                                                               | <p><i>Least privilege.</i></p> <p>The workload will be protected from <b>unauthorized access</b> and prohibited activities. Even when access is from trusted identities, the <b>access permissions and exposure time will be minimized</b> because the communication path is open for a limited period.</p>                                                                                                                                                                                                                                                   |
| <p><b>Classify data based on its type, sensitivity, and potential risk.</b> Assign a confidentiality level for each.</p> <p>Include system components that are in scope for the identified level.</p> | <p><i>Verify explicitly.</i></p> <p>This evaluation helps you right-size security measures.</p> <p>You'll also be able to identify data and components that have a <b>high potential impact</b> and/or exposure to risk. This exercise adds <b>clarity</b> to your information protection strategy and helps ensure <b>agreement</b>.</p>                                                                                                                                                                                                                     |
| Safeguard your data at rest, in transit, and during processing by using <b>encryption</b> . Base your strategy on the assigned confidentiality level.                                                 | <p><i>Assume breach.</i></p> <p>Even if an attacker gets access, they <b>won't be able to read properly encrypted</b> sensitive data.</p> <p>Sensitive data includes configuration information that's used to gain further access inside the system. Data encryption can help you <b>contain risks</b>.</p>                                                                                                                                                                                                                                                   |
| <b>Guard against exploits</b> that might cause unwarranted exposure of information.                                                                                                                   | <p><i>Verify explicitly.</i></p> <p>It's crucial to minimize vulnerabilities in authentication and authorization implementations, code, configurations, operations, and those that stem from the social habits of the system's users.</p> <p>Up-to-date security measures enable you to <b>block known security vulnerabilities</b> from entering the system. You can also <b>mitigate new vulnerabilities</b> that can appear over time by implementing routine operations throughout the development cycle, continuously improving security assurances.</p> |
| <b>Guard against data exfiltration</b> that results from malicious or inadvertent access to data.                                                                                                     | <p><i>Assume breach.</i></p> <p>You'll be able to contain blast radius by <b>blocking unauthorized data transfer</b>. Additionally, controls applied to networking, identity, and encryption will protect data at various layers.</p>                                                                                                                                                                                                                                                                                                                         |
| <b>Maintain the level of confidentiality</b> as data flows through various components of the system.                                                                                                  | <p><i>Assume breach.</i></p> <p>Enforcing confidentiality levels throughout the system enables you to provide a consistent level of hardening. Doing so can <b>prevent</b></p>                                                                                                                                                                                                                                                                                                                                                                                |

| Approach                                                          | Benefit                                                                                                                                              |
|-------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                   | <b>vulnerabilities</b> that might result from moving data to a lower security tier.                                                                  |
| Maintain an <b>audit trail</b> of all types of access activities. | <i>Assume breach.</i><br><br>Audit logs support <b>faster detection and recovery</b> in case of incidents and help with ongoing security monitoring. |

## Design to protect integrity

[Expand table](#)

**Prevent corruption of design, implementation, operations, and data to avoid disruptions that can stop the system from delivering its intended utility or cause it to operate outside the prescribed limits. The system should provide information assurance throughout the workload lifecycle.**

The key is to implement controls that prevent tampering of business logic, flows, deployment processes, data, and even the lower stack components, like the operating system and boot sequence. Lack of integrity can introduce vulnerabilities that can lead to breaches in confidentiality and availability.

[Expand table](#)

| Approach                                                                                                                                                                                                                                                                                                                | Benefit                                                                                                                                                                                                                                                                                                |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Implement strong access controls that authenticate and authorize access to the system.</b><br><br><b>Minimize access based on privilege, scope, and time.</b>                                                                                                                                                        | <i>Least privilege.</i><br><br>Depending on the strength of the controls, you'll be able to <b>prevent or reduce risks from unapproved modifications</b> . This helps ensure that data is consistent and trustworthy.<br><br>Minimizing access limits the extent of potential corruption.              |
| <b>Continuously protect against vulnerabilities and detect them in your supply chain</b> to block attackers from injecting software faults into your infrastructure, build system, tools, libraries, and other dependencies.<br><br>Supply chain should scan for vulnerabilities during <b>build time and runtime</b> . | <i>Assume breach.</i><br><br>Knowing the origin of software and verifying its authenticity throughout the lifecycle will <b>provide predictability</b> . You'll <b>know about vulnerabilities well in advance</b> so that you can proactively remediate them and keep the system secure in production. |

| Approach                                                                                                                                                                                                  | Benefit                                                                                                                                                                                                                                                                                                                                                                                             |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Establish trust and verify by using cryptography techniques</b> like attestation, code signing, certificates, and encryption.</p> <p>Protect those mechanisms by allowing reputable decryption.</p> | <p><i>Verify explicitly, least privilege.</i></p> <p>You'll know that changes to data or access to the system is <b>verified by a trusted source</b>.</p> <p>Even if encrypted data is intercepted in transit by a malicious actor, the actor won't be able to unlock or decipher the content. You can use digital signatures to ensure that the data wasn't tampered with during transmission.</p> |
| <p><b>Ensure backup data is immutable and encrypted</b> when data is replicated or transferred.</p>                                                                                                       | <p><i>Verify explicitly.</i></p> <p>You'll be able to recover data with confidence that backup <b>data wasn't changed at rest</b>, inadvertently or maliciously.</p>                                                                                                                                                                                                                                |
| <p><b>Avoid or mitigate system implementations that allow your workload to operate outside its intended limits and purposes.</b></p>                                                                      | <p><i>Verify explicitly.</i></p> <p>When your system has strong safeguards that check whether usage aligns with its intended limits and purposes, the scope for potential abuse or tampering of your compute, networking, and data stores is reduced.</p>                                                                                                                                           |

## Design to protect availability

 Expand table



**Prevent or minimize system and workload downtime and degradation in the event of a security incident by using strong security controls. You must maintain data integrity during the incident and after the system recovers.**

You need to balance availability architecture choices with security architecture choices. The system should have availability guarantees to ensure that users have access to data and that data is reachable. From a security perspective, users should operate within the allowed access scope, and the data must be trusted. Security controls should block bad actors, but they shouldn't block legitimate users from accessing the system and data.

 Expand table

| Approach                                                                                                                                                                                          | Benefit                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Prevent compromised identities from misusing access</b> to gain control of the system.</p> <p>Check for <b>overly pervasive scope and time limits</b> to minimize risk exposure.</p>        | <p><i>Least privilege.</i></p> <p>This strategy <b>mitigates the risks of excessive, unnecessary, or misused access permissions</b> on crucial resources. Risks include unauthorized modifications and even the deletion of resources. Take advantage of the platform-provided just-in-time (JIT), just-enough-access (JEA), and time-based security modes to replace standing permissions wherever possible.</p>                       |
| <p>Use security controls and design patterns to <b>prevent attacks and code flaws from causing resource exhaustion</b> and blocking access.</p>                                                   | <p><i>Verify explicitly.</i></p> <p>The <b>system won't experience downtime</b> caused by malicious actions, like distributed denial of service (DDoS) attacks.</p>                                                                                                                                                                                                                                                                     |
| <p>Implement <b>preventative measures for attack vectors that exploit vulnerabilities</b> in application code, networking protocols, identity systems, malware protection, and other areas.</p>   | <p><i>Assume breach.</i></p> <p>Implement code scanners, apply the latest security patches, update software, and protect your system with effective antimalware on an ongoing basis.</p> <p>You'll be able to reduce the attack surface to ensure business continuity.</p>                                                                                                                                                              |
| <p><b>Prioritize</b> security controls on the <b>critical components and flows</b> in the system that are susceptible to risk.</p>                                                                | <p><i>Assume breach, verify explicitly.</i></p> <p>Regular detection and prioritization exercises can help you <b>apply security expertise to the critical aspects</b> of the system. You'll be able to focus on the most likely and damaging threats and start your risk mitigation in areas that need the most attention.</p>                                                                                                         |
| <p>Apply at least the same level of <b>security rigor in your recovery resources and processes</b> as you do in the primary environment, including security controls and frequency of backup.</p> | <p><i>Assume breach.</i></p> <p>You should have a preserved safe system state available in disaster recovery. If you do, you can fail over to a secure secondary system or location and restore backups that won't introduce a threat.</p> <p>A well-designed process can prevent a security incident from hindering the recovery process. Corrupted backup data or encrypted data that can't be deciphered can slow down recovery.</p> |

## Sustain and evolve your security posture

 Expand table





**Incorporate continuous improvement and apply vigilance to stay ahead of attackers who are continuously evolving their attack strategies.**

Your security posture must not degrade over time. You must continually improve security operations so that new disruptions are handled more efficiently. Strive to align improvements with the phases defined by industry standards. Doing so leads to better preparedness, reduced time to incident detection, and effective containment and mitigation. Continuous improvement should be based on lessons learned from past incidents.

It's important to measure your security posture, enforce policies to maintain that posture, and regularly validate your security mitigations and compensating controls in order to continuously improve your security posture in the face of evolving threats.

[Expand table](#)

| Approach                                                                                                                                                                                                                                                                                                                                | Benefit                                                                                                                                                                                                                                                                                                                                                                                          |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Create and maintain a comprehensive asset inventory</b> that includes classified information about resources, locations, dependencies, owners, and other metadata that's relevant to security.</p> <p>As much as possible, <b>automate</b> inventory to derive data from the system.</p>                                          | <p>A well-organized inventory provides a <b>holistic view of the environment</b>, which puts you in an advantageous position against attackers, especially during post-incident activities.</p> <p>It also creates a business rhythm to drive communication, upkeep of critical components, and the decommissioning of orphaned resources.</p>                                                   |
| <p><b>Perform threat modeling</b> to identify and mitigate potential threats.</p>                                                                                                                                                                                                                                                       | <p>You'll have a <b>report of attack vectors</b> prioritized by their severity level. You'll be able to identify threats and vulnerabilities quickly and set up countermeasures.</p>                                                                                                                                                                                                             |
| <p>Regularly <b>capture data to quantify your current state</b> against your established security baseline and <b>set priorities for remediations</b>.</p> <p>Take advantage of platform-provided features for <b>security posture management and the enforcement of compliance</b> imposed by external and internal organizations.</p> | <p>You need accurate reports that bring clarity and consensus to focus areas. You'll be able to immediately <b>execute technical remediations</b>, starting with the highest priority items. You'll also <b>identify gaps</b>, which provide opportunities for improvement.</p> <p>Implementing enforcement helps prevent violations and regressions, which preserves your security posture.</p> |
| <p><b>Run periodic security tests</b> that are conducted by experts external to the workload team who attempt to ethically hack the system.</p> <p>Perform routine and integrated <b>vulnerability</b></p>                                                                                                                              | <p>These tests enable you to validate security defenses by <b>simulating real-world attacks</b> by using techniques like penetration testing.</p> <p>Threats can be introduced as part of your change management. Integrating scanners into the deployment pipelines enables you to automatically detect</p>                                                                                     |

| Approach                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Benefit                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>scanning</b> to detect exploits in infrastructure, dependencies, and application code.                                                                                                                                                                                                                                                                                                                                                                                                        | vulnerabilities and even quarantine usage until the vulnerabilities are removed.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Detect, respond, and recover</b> with swift and effective security operations.                                                                                                                                                                                                                                                                                                                                                                                                                | <p>The primary benefit of this approach is that it enables you to <b>preserve or restore the security assurances of the CIA triad</b> during and after an attack.</p> <p>You need to be alerted as soon as a threat is detected so that you can start your investigations and take appropriate actions.</p>                                                                                                                                                                                                                                                                                                          |
| <b>Conduct post-incident activities</b> like root-cause analyses, postmortems, and incident reports.                                                                                                                                                                                                                                                                                                                                                                                             | These activities provide insight into the impact of the breach and into resolution measures, which drives improvements in defenses and operations.                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>Get current, and stay current.</b><br><br>Stay current on updates, patching, and security fixes.<br><br>Continuously evaluate the system and improve it based on audit reports, benchmarking, and lessons from testing activities. Consider automation, as appropriate.<br><br>Use threat intelligence powered by security analytics for dynamic detection of threats.<br><br>At regular intervals, review the workload's conformance to Security Development Lifecycle (SDL) best practices. | <p>You'll be able to ensure that your <b>security posture doesn't degrade over time</b>.</p> <p>By integrating findings from real-world attacks and testing activities, you'll be able to combat attackers who continuously improve and exploit new categories of vulnerabilities.</p> <p>Automation of repetitive tasks <b>decreases the chance of human error</b> that can create risk.</p> <p>SDL reviews bring clarity around security features. SDL can help you maintain an inventory of workload assets and their security reports, which cover origin, usage, operational weaknesses, and other factors.</p> |

## Next steps

[Security checklist](#)

Last updated on 11/15/2023